



THE INDIAN DPDP ACT 2023 – Analysis and Implementation Challenges

India finally has a personal data protection law, called the Digital Personal Data Protection (DPDP) Act 2023. The first draft of this law was made available for public comment on November 18, 2022. The cabinet approved this draft with some modifications on 5th July 2023. The draft bill was introduced in the Lok Sabha on 3rd August 2023 and was passed by the Lok Sabha on August 7, 2023. Rajya Sabha passed the bill on 9 August 2023. The bill received the assent of the President of India on 11th August 2023 and, from a Bill, became the Digital Personal Data Protection Act 2023. From making the draft available to the public for comment to final assent by the President of India, the whole process had taken a little under nine months. This was a rapid conclusion to a long, drawn-out process that had seen an earlier draft bill tabled in 2018 and finally discarded in 2022.

The Prelude

In a landmark judgment delivered on August 24, 2017, now popularly known as the Puttaswamy judgement, a 9-judge bench unanimously ruled that every citizen of India had a fundamental right to privacy, which was guaranteed by the Constitution of India within Article 21 in particular and Part III on the whole. In response to the need to protect citizens' personal data, the Union Government of India, acting through the Ministry of Electronics and Information Technology, constituted a Committee of experts to deliberate on a data protection framework for India. Justice B. N. Srikrishna was appointed as the Chairman, and the committee was given the following terms of reference: a) To study various issues relating to data protection in India; b) To make specific suggestions for consideration of the Central Government on principles to be considered for data protection in India and suggest a draft data protection bill. The Committee completed its work and submitted its report and a draft Personal Data Protection Bill to the Ministry of Electronics and Information Technology for further consideration on July 27, 2018. This document is the (Indian) Draft Personal Data Protection Bill (PDP) 2018. The Draft PDP Bill of 2018 was reviewed internally by the Union Government and was tabled in Lok Sabha as Bill No. 373 of 2019. This Draft Bill was referred to a Joint Parliamentary Committee (JPC) by the Lok Sabha on December 11, 2019. This Bill was also referred to the above-mentioned Joint Parliamentary Committee by the Rajya Sabha on December 12, 2019. The JPC made a total of 91 recommendations for change as part of their report. A total of 8 members of this JPC submitted dissent notes/memos, which were annexed to the report. The Government decided not to proceed with the PDP Bill and rapidly submitted a much-simplified draft, possibly benefitting from the extensive discussions at all forums that had already taken place.

The Srikrishna Committee of Experts built upon earlier work by a Group of Experts done under the chairmanship of Justice A.P. Shah. This group of experts was set up on September 29, 2011 and submitted its report on October 16, 2023.

Changing Objectives

We can see that the journey to bring in legislation to protect privacy has been a long one. Looking at the past efforts, the objectives have undergone some changes.

There has been a shift from protecting privacy to protecting personal data and a shift from personal data to digital personal data. Also, from being envisaged as an Act that would protect the citizens from the State and other entities, it now enables that state to process citizens' personal data for lawful purposes. The adversarial aspect of the State-citizen relationship viz-a-viz privacy has been left out of its purview.



Sundeep Oberoi
Adjunct Professor – ADCPS
IIT Bombay



Purnima Rohilla
Ph.D. Research Scholar, ADCPS
IIT Bombay



Soundarya Lakshmi
Ph.D. Research Scholar, ADCPS,
IIT Bombay

relationship viz-a-viz privacy has been left out of its purview. We do not engage further with any analysis of the objectives of the Act and whether it is or is not in line with the evolution of privacy-related initiatives in India. In the rest of the article, we concentrate on the practical aspects of implementing the Act and highlight some important challenges.

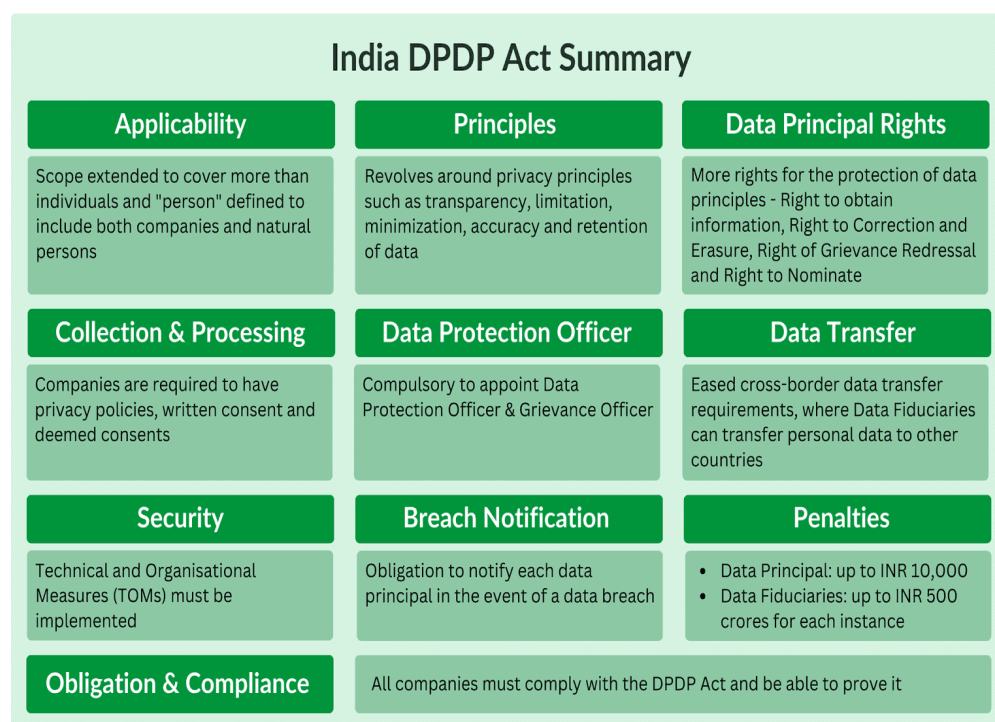
Implementation Aspects

This article looks at four critical aspects of implementing the DPDP Act 2023. These are:

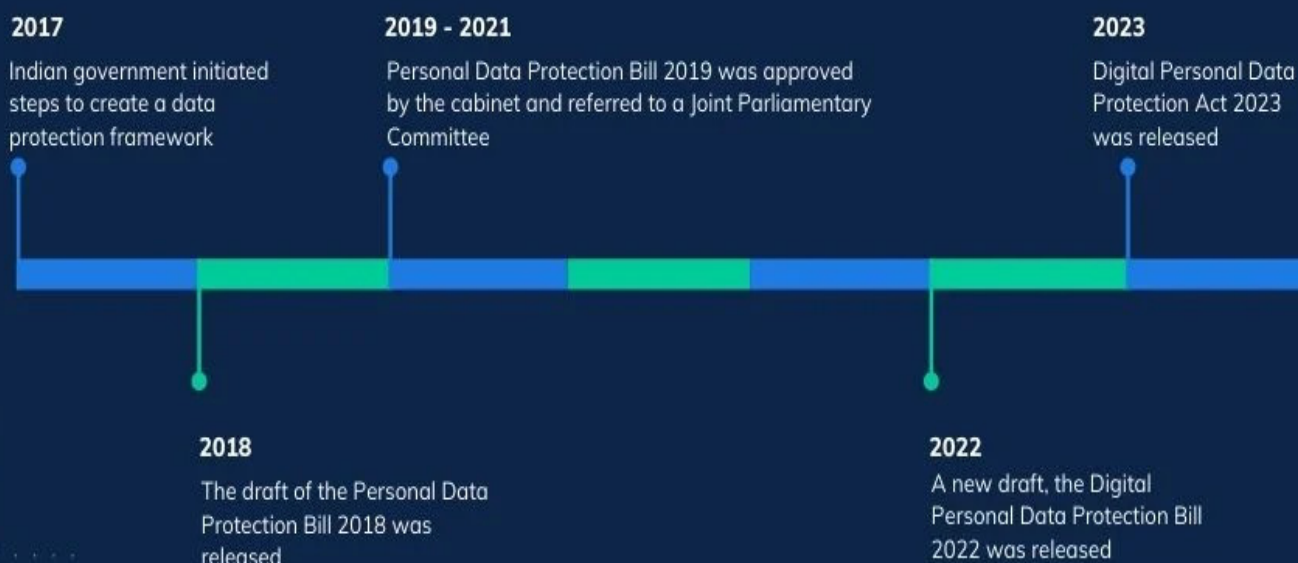
1. Awareness of requirements, adequacy of measures and skill aspects
2. Practical engineering aspects
3. Legal aspects
4. Scale aspects

Awareness of requirements, adequacy of measures and skill aspects

Several provisions within the DPDP Act are left vulnerable to the subjective interpretation and discretion of the Board and Central government. This raises concerns of ambiguity, arbitrary rule-making and context-dependent interpretation of ‘best practices’ – which could widen the gap between intent and implementation.



Background of DPDP Act





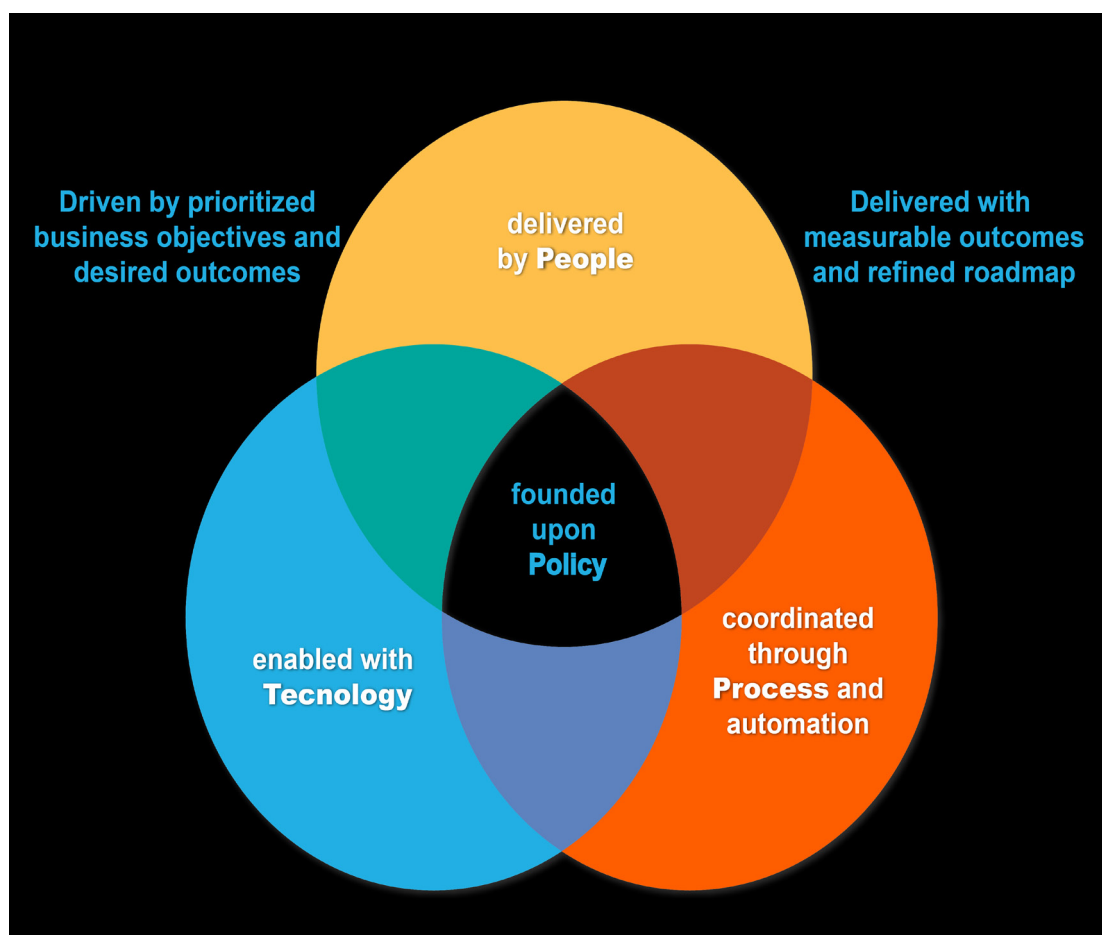
The DPDP Act imposes heightened data management requirements upon data fiduciaries. An obligation has been placed on data fiduciaries to safeguard the personal data in their possession by implementing “reasonable security measures” [Section 8(5)] to prevent breaches. However, the DPDP Act does not specify any objective standard to aid the assessment of adherence to such ‘reasonable security measures’. This is a significant lacuna, considering non-compliance attracts penalties up to 250 crore.

The Act also requires data fiduciaries to ensure “completeness, accuracy and consistency” when processing personal data for decisions capable of affecting the data principle [Section 8(3)]. However, there is no objective criteria to assess if the requirements are met. The absence of standardised interpretation raises the question, whether the dispute resolution authority can assess compliance in a non-discriminatory and standardised manner and if the Data fiduciary would even be aware of non-compliance to the Act’s requirements.

The converse of data fiduciary obligations is the rights of the data principal. The Act again guarantees a plethora of rights to the data principal, including the right to access personal data information [Section 11], the right to correct personal data [Section 12(2)], and the right to be forgotten [Section 12(3)]. To ensure such rights are upheld, the data fiduciary must perform its obligations. In the absence of standards to determine “due diligence” on the part of the Data Fiduciary, the rights provided under this Act remain superficial, with a high risk of uncertainty.

To ensure and ascertain compliance of data fiduciaries to the legislative intent of this Act, the Data fiduciary must be capable of locating all its data, meaningfully classifying the available data and setting up a consent management system for processing this data. This would require the Data fiduciaries to revamp the existing data management system significantly or, in some cases, introduce one for the first time. However, owing to the complex multidimensional nature of data and the potential for subjective interpretation of the Act, implementing such a data management system and its compliance ascertainment becomes cumbersome. This brings in the need for standardization as a key implementation aid.

The Bureau of Indian Standards (BIS) has recently published a standard IS 19326:2023, Information Technology – Adequacy of Organizational Data Governance and Management Practices, that provides practical inputs on what are the essential data governance and management practices and their expected outcomes as well as sets a minimum threshold on their performance.



Practical Engineering Aspects

Adopting the Act without a robust data governance framework requires organisations to navigate several transformations. Additional tools, processes, and training might be needed to ensure compatibility with existing data or to convert the data to fit the new systems. Organisations with less mature data governance and management practices may face higher challenges.

Important aspects of DPDP Act



Organisations

- Data Protection and Security
- Consent
- Notification
- Language and Clarity
- Withdrawal of Consent
- Data Erasure
- Special Cases
- Significant Data Fiduciaries
- Accountability



Individuals

Rights:

- Right to access personal data
- Right to correction and erasure of data
- Right to grievance redressal
- Right to nominate a consent manager

Duties:

- To comply with all applicable laws
- To not impersonate another person
- To not suppress any material information
- To not register false or frivolous grievances or complaints
- To furnish only verifiably authentic information for corrections or erasures

The new Act focuses heavily on consent and “consent managers” to control data use (Refer to Section 6). It says consent must be specific to a purpose. But how specific? This means that there needs to be a codification of purposes to avoid ambiguity. Should this codification be coarse-grained or fine-grained? For example, should we ask hospital portal users for consent for each service (appointments, checkups) or just one for all services?

Apart from the granularity of consent, are the consent managers merely to seek consent and in case of a dispute present, according to their records, whether consent was given in a particular instance or are the IT systems expected to affirm and enforce consent for every processing instance technically?

The issue of integrating consent management into the data processors’ IT systems is considerably complex. It seems impossible without interoperability standards.

The Indian Ministry of Electronics and Information Technology (MEITY) has released an Electronic Consent Framework – Technology Specifications 1.1. This document lays down certain requirements for recording consent and processing based on the recorded consent. The framework defines a consent artefact as the basic element for recording consent. The problems which are significant in our assessment are described below:

1. It is essential that a digital signature be included in every consent artefact.
2. In the case of data shares initiated by the data consumer, the data provider must verify the signature in the consent artefact before granting access to data.

The Digital Signature is recognised as a legally valid signature under the Indian Information Technology Act. There is an overhead in terms of the issuance and management of legally valid digital certificates. Currently, there are about 50 lakh valid digital certificates in the ecosystem. These are required to be issued on a hardware token, and each verification requires a certificate revocation list scan or an OCSP call. This is completely impractical if consent is to be verified on each access. There is an alternative available, called ‘eSign’. This method involves an ephemeral digital certificate valid



only for 30 minutes. In this scheme, the backend application will hold the private key, which is discarded after a single use. Apart from these significant challenges with digital signatures, the purpose of processing, to the extent specified in the framework, is very coarsely grained and seems to be at the level of granting access to data rather than at a finer grain. In order to implement fine-grained specifications of purpose, further standardisation may be needed.

Legal Aspects

The DPDP Act does not provide for criminal penalties in case of violation of its provisions. The penalties referred to under Section 33 are monetary in nature and specified in the Schedule. In the absence of punitive measures, it might seem that the focus of the Act is on compensating the Data Principal monetarily. However, the same is not true either. Section 34 reads as follows:

Additionally, the Act also omits Section 43A of the Information Technology Act, which requires compensation

to be paid to the Data Principal when a corporate body fails to protect personal data [Section 44(2)(a)]. Along similar lines, Section 44(2)(c) of the DPDP Act omits Section 87(2)(ob) of the IT Act, which requires the Central Government to lay down Rules clarifying the contours of “sensitive personal data or information” and “reasonable security practices and procedures” to be followed by corporate bodies in handling personal data – against the breach of which the Data Principal can seek to be compensated. In this way, the DPDP Act not only fails to provide compensation to the Data Principal but also ensures to obstruct alternate avenues for compensation by striking down two crucial provisions under the IT

“

All sums realised by way of penalties imposed by the Board under this Act, shall be credited to the Consolidated Fund of India.

”

“

Any person who has suffered material or non-material damage as a result of an infringement of this Regulation shall have the right to receive compensation from the controller or processor for the damage suffered.

[Article 82, GDPR]

”

Act. This sets a trajectory widely different from the European Union’s General Data Protection Regulation (GDPR), where Article 82 reads as follows:

Therefore, the General Data Protection Regulation (GDPR) expressly recognizes the rights of a Data Principal to be compensated, while the Indian DPDP Act does not provide such provisions.

The way in which the Act is structured may discourage a Data Principal from seeking redress. For instance, the earlier 2019 Bill, the 2019 Joint Parliamentary Committee Report as well as the 2022 Bill had defined ‘harm’ to the Data Principal as “any bodily harm; or distortion or theft of identity; or harassment; or prevention of lawful gain or causation

of significant loss” – the occurrence of which would provide a *locus standi* for the Data Principal to approach the Board; however, this concept is removed from the 2023 Act. Furthermore, the Act states that the Data Principal shall be fined 10,000 rupees if his complaint is found to be false or frivolous [Section 15(d) read with the Schedule]. Therefore, the limited capacity to handle cases, the sense of ambiguity surrounding the occurrence of a ‘harm’ and the deterrence of a fine in the event of a frivolous complaint can cumulatively discourage a Data Principal from filing a complaint.

The DPDP Act also tends to disregard the established legal process in certain cases. For instance, Section 7(e) of the Act empowers the Data Fiduciaries to directly process personal data in compliance with a foreign judgment, without

the prior approval of the Indian judiciary. Section 7(e) reads as follows:

This circumvents the due process laid down under Sections 13 and 14 of the Civil Procedure Code.

Furthermore, the phrase “as may be prescribed” appears nearly 26 times in the 20-page Act, leaving a lot to be notified by the Government through Rules later. Given the complicated nature of the subject matter itself and that it is not clear how these rules will be framed, it leaves us in a state of ambiguity.

“

A Data Fiduciary may process personal data of a Data Principal for compliance with any judgment or decree or order issued under any law for the time being in force in India, or any judgment or order relating to claims of a contractual or civil nature under any law for the time being in force outside India (Emphasis provided)

”

Scale Aspects

The DPDPA 2023 will impact every citizen and every organization. The number of people and organizations is so large that skill upgrades, awareness training, and compliance planning will have to be undertaken at a very large scale.

On the technology and system change front, the changes required to all existing applications will be significant, and so will the cost. It is informative to recall the cost and complexity of fixing the Year 2000 problem (also known as the Y2K problem). The problem was conceptually simple, but fixing it was assessed at a cost between \$100 billion and \$200 billion globally. It is imperative that the technical methodology of all interoperability requirements be standardised on an urgent basis. If this is not done, the whole system will degenerate into an offline record-keeping exercise where some databases store some user consent records, but this is not integrated with the actual processing, and the whole exercise becomes meaningless, just like the DND telephone registries today.

Further, the dispute resolution mechanism under the DPDP Act may face scalability challenges. The Act provides for a single Data Protection Board with a Chairperson and Members as the adjudicating authority, while the appeal lies with the Telecom Disputes Settlement & Appellate Tribunal (TDSAT). The proposed singular Data Protection Board is expected to deal with all cases arising out of the DPDP Act. Also, procedural safeguards, such as rules of evidence and strict legal procedures, may be less formal in a Board setting compared to a Tribunal. Therefore, the adjudicating authority seems to be designed with the capacity to handle only a limited number of cases.

The Bill specifies the Board’s headquarters location but fails to address the crucial issue of regional representation. It also remains unclear if the board will function as a singular body or if there will be a hierarchical system similar to the Indian Court System. However, it does mention the following:

The Board shall function as an independent body and shall, as far as practicable, function as a digital office, with the receipt of complaints and the allocation, hearing and pronouncement of decisions in respect of the same being digital by design, and adopt such techno-legal measures as may be prescribed.

With the current state of Public Digital Infrastructure (PDI) in India, designating the centralised adjudicating authority as a digital office would bring in its own set of challenges – such as reliability and cybersecurity, as well as mass access challenges in a digital office of the required scale. This raises additional questions about the Board’s geographical reach and accessibility for individuals seeking recourse.

On the subject of qualifications and skills required of the members of the board, the Bill has the following requisition:

The Chairperson and other Members shall be a person of ability, integrity and standing who possesses special knowledge or practical experience in the fields of data governance, administration or implementation of laws related to



social or consumer protection, dispute resolution, information and communication technology, digital economy, law, regulation or techno-regulation, or in any other field which in the opinion of the Central Government may be useful to the Board, and at least one among them shall be an expert in the field of law.

The phrase “person possesses special knowledge or practical experience” is ambiguous, and there is a lack of specificity and no clarification on the desired level of expertise. Also, given the diverse fields mentioned in the statement, the terms “special knowledge” and “practical experience” are open to subjective interpretations. In contrast, the requirement of being “an expert in the field of law” is clearly defined and objectively assessable, thanks to an established ecosystem for verifying legal expertise. To successfully implement this law, there is a long way to go. An ecosystem that generates the specialised skills required in various fields mentioned in the Bill, is yet to be established. For example, there exists a well-established system, if not perfect, that is able to produce doctors, chartered accountants, etc. The groundwork is laid at the secondary and higher education levels and goes up to specialised professional degrees. A similar ground-up approach is needed to ensure we have professionals with the skills required to implement the provisions of the Bill.

While the Bill emphasises the importance of diverse expertise on the board, a centralised structure might struggle to provide the necessary depth of knowledge and practical skills. To effectively implement the Data Protection Law, instead of relying on a limited number of members with broad backgrounds, the Board should consider forming specialised teams dedicated to specific fields like law, technology, and data security.

Which organisations does DPDP Act apply to?

**DPDP Act
2023**



Organisations based in India

Organisations that handle digital
personal data



Organisations based outside India

Organisations that process personal
data related to offering goods or
services to individuals in India.

Conclusion

The DPDP Act 2023 is certainly simpler than the Personal Data Protection Bill 2019. Simpler may mean easier to understand and implement but may not implement the level of protection desired in terms of privacy.

Even this simpler version has several implementation challenges, which are due to the complexity of the subject rather than any particular infirmities in the Act itself.

Implementation will require major efforts to scale. These implementation requirements will also have a significant cost associated with them. Organisations will have to do an impact analysis to draw up plans to enhance their systems in order to be compliant.

Given the current gaps in the policy sub-system, it is clear that the scale and pace of changes required in technical and non-technical aspects of the digital personal data protection regime are daunting. Further, the fact that technological innovations are far outpacing existing regulatory instruments means that these changes need to be conceptualised and institutionalised as fast as possible. The Board, therefore, must be a broad-based body with the authority to design, enact, and enforce multiple policy instruments simultaneously. This requires clear, unambiguous devolution of functions to the Board – to be developed through continuous and constructive deliberations between governmental and non-governmental bodies.

Implementing a crucial law solely through a digital office could face challenges unless the Board establishes a robust subordinate structure with a tangible geographical presence. The Indian judicial system follows a subordinate or a hierarchical system and has geographical outreach, and we are all aware of the pendency of cases in our courts.

Finally, the system relies upon the willingness of competent and trustworthy organisations to act as consent managers. The risk-reward tradeoff seems unclear due to the lack of principles on determining fines in specific instances. The business model for consent managers is also unclear at this point in time, and if organizations do not step up to function as consent managers, the Act may face several delays in its implementation.

References

1. Government of India, Ministry of Electronics and Information Technology. (2023). The Digital Personal Data Protection Act, 2023. Act No. 22, [11th August 2023].
<https://www.meity.gov.in/writereaddata/files/Digital%20Personal%20Data%20Protection%20Act%202023.pdf>
2. Government of India, Ministry of Electronics and Information Technology. (2022). The Digital Personal Data Protection Bill, 2022. https://www.meity.gov.in/writereaddata/files/The%20Digital%20Personal%20Data%20Protection%20Bill%202022_0.pdf
3. Supreme Court of India. (2017). Justice K.S. Puttaswamy (Retd.) and Another v. Union of India and Others, 10 SCC 1. https://main.sci.gov.in/supremecourt/2012/35071/35071_2012_Judgement_24-Aug-2017.pdf
4. Government of India. (1950). The Constitution of India. Article 21.
5. Government of India, Ministry of Electronics and Information Technology. (2018). The Personal Data Protection Bill, 2018
https://www.meity.gov.in/writereaddata/files/Personal_Data_Protection_Bill,2018.pdf
6. Government of India, Ministry of Electronics and Information Technology. (2018). Committee of Experts under the Chairmanship of Justice B.N. Srikrishna
https://www.meity.gov.in/writereaddata/files/Data_Protection_Committee_Report.pdf
7. Bureau of Indian Standards, (2023). Information Technology – Adequacy of Organizational Data Governance and Management Practices. IS 19326:2023
https://www.services.bis.gov.in/tmp/WCLITD23319326_10082023_2.pdf
8. Ministry of Electronics and Information Technology, (2022). Electronic Consent Framework – Technology Specifications 1.1.
<https://dla.gov.in/sites/default/files/pdf/MeitY-Consent-Tech-Framework%20v1.1.pdf>
9. European Union, (2016). Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), OJ 2016 L 119/1
<https://gdpr-info.eu/>
10. Government of India. (1908). The Code of Civil Procedure, 1908. Sections 13 and 14 ■